APOSTILA DE FUNDAMENTOS DE CYBERSECURITY

Backup dos conteúdos estudados e reforçados

Linux • Redes • Protocolos • Segurança da Informação • SOC • Blue Team

Material de revisão pessoal — linguagem simples, foco em compreensão e aplicação.

Como usar esta apostila

Este material foi criado para preservar o conhecimento construído durante a preparação para Cybersecurity. A ideia não é decorar definições, mas entender o que cada conceito significa, como ele se relaciona com os demais e por que é importante para segurança.

> Regra de estudo: se você consegue explicar um conceito com suas próprias palavras, dar um exemplo e reconhecer esse conceito em uma situação real, o aprendizado está mais próximo de ser sólido.

Sumário

- 1. Sistemas Operacionais
- 2. Linux
- 3. Redes de Computadores
- 4. Topologias de Rede
- 5. Internet e Endereçamento
- 6. Portas e Protocolos
- 7. DNS e DHCP
- 8. Web e Criptografia
- 9. Identidade e Controle de Acesso
- 10. Segurança da Informação
- 11. Malware e Engenharia Social
- 12. SOC, EDR, SIEM e Logs
- 13. Incidentes e Indicadores
- 14. Blue Team e Red Team
- 15. Vulnerabilidades, Riscos e Hardening
- 16. Engenharia Reversa e Laboratórios
- 17. Revisão Comparativa
- 18. Glossário
- 19. Questões de Fixação

1. Sistemas Operacionais

O que é um sistema operacional?

É o software responsável por gerenciar os recursos do computador e oferecer uma base para que outros programas funcionem. Ele administra CPU, memória, armazenamento, dispositivos, usuários e processos.

Kernel

O kernel é o núcleo do sistema operacional. Ele faz a ponte entre os programas e o hardware e controla operações que exigem acesso privilegiado.

2. Linux

O que é Linux?

Linux é um kernel usado por várias distribuições, como Ubuntu, Debian, Fedora e Kali Linux. Em segurança, aparece com frequência em servidores, infraestrutura, nuvem, ferramentas e laboratórios.

Terminal

O terminal permite interagir com o sistema por comandos de texto. Exemplos: **ls** lista conteúdo de um diretório; **cd** muda de diretório.

Arquivos e diretórios

Diretórios organizam arquivos e outros diretórios. No Linux, a raiz da estrutura é representada por /. A organização é hierárquica.

Usuários e permissões

Permissões controlam quem pode ler, alterar ou executar recursos. Em Linux, r representa leitura, w escrita e x execução. O princípio do menor privilégio determina que cada usuário ou processo tenha somente as permissões necessárias.

Processos

Processo é um programa em execução. Processos utilizam CPU, memória, arquivos e rede. Em segurança, observar processos ajuda a identificar comportamentos anormais.

3. Redes de Computadores

O que é uma rede?

É um conjunto de dispositivos capazes de se comunicar seguindo regras e protocolos. Pode envolver computadores, celulares, servidores, roteadores, switches e dispositivos IoT.

PAN, LAN, MAN e WAN

PAN cobre uma área pessoal, como dispositivos conectados por Bluetooth. LAN cobre uma área local, como uma casa ou empresa. MAN cobre uma área metropolitana. WAN cobre grandes distâncias; a Internet é uma enorme interconexão de redes.

Por que redes importam em Cybersecurity?

Ataques, defesas e investigações frequentemente envolvem tráfego, endereços IP, portas, protocolos, DNS, serviços e comunicação entre máquinas.

4. Topologias de Rede

Estrela

Os dispositivos se conectam a um equipamento central, geralmente um switch. É fácil de organizar e uma falha em um cabo costuma afetar apenas aquele dispositivo, mas uma falha no ponto central pode afetar vários nós.

Barramento

Os dispositivos compartilham um meio principal de comunicação. É uma arquitetura histórica, simples, mas menos adequada às redes modernas por questões de confiabilidade e escalabilidade.

Anel

Os dispositivos formam um circuito. Cada nó se conecta a outros nós do caminho. O comportamento diante de falhas depende da implementação.

Malha

Existem vários caminhos entre os dispositivos. A redundância aumenta a disponibilidade, mas a implementação é mais complexa.

Árvore

Organiza a rede de forma hierárquica, com níveis e ramificações. É útil para redes maiores, nas quais diferentes segmentos precisam ser organizados.

Comparação

Estrela favorece simplicidade e manutenção; malha favorece redundância; árvore favorece organização hierárquica; barramento e anel são arquiteturas mais associadas a contextos específicos ou históricos.

5. Internet e Endereçamento

ARPANET

Foi uma rede precursora da Internet e teve papel importante no desenvolvimento de tecnologias de comunicação entre computadores.

Internet

Não é uma única rede. É uma interconexão de redes que utilizam padrões comuns para trocar dados.

IP

Internet Protocol é usado para endereçar e encaminhar dados entre redes. Um IPv4 é representado por quatro grupos, como 192.168.1.10.

IPv4 x IPv6

IPv4 usa 32 bits e possui espaço de endereçamento limitado. IPv6 usa 128 bits e oferece uma quantidade muito maior de endereços.

MAC Address

É um identificador associado à interface de rede. É especialmente relevante na comunicação local. IP é um endereço lógico usado no encaminhamento; MAC identifica a interface no enlace local.

Roteador x Switch

O switch conecta dispositivos dentro de uma rede local e usa informações como MAC para encaminhar quadros. O roteador conecta redes diferentes e encaminha pacotes entre elas.

6. Portas e Protocolos

Portas de rede

Uma porta é um número usado para identificar um serviço ou aplicação em uma máquina. Os números vão de 0 a 65535. Exemplo: 192.168.1.10:443. O IP indica o destino e a porta indica o serviço associado à comunicação.

Portas comuns

22 costuma ser SSH; 21 FTP; 25 SMTP; 53 DNS; 80 HTTP; 443 HTTPS; 3389 RDP. A associação é convencional, não uma garantia: um administrador pode configurar serviços em portas diferentes.

Protocolo

É um conjunto de regras que define como dispositivos se comunicam. Exemplos: TCP, UDP, DNS, HTTP, HTTPS e SSH.

TCP

É orientado à conexão e oferece mecanismos de confiabilidade, ordenação, retransmissão e controle de fluxo.

UDP

É mais simples e tem menor sobrecarga. Não fornece as mesmas garantias de entrega e ordenação do TCP. Pode ser útil quando baixa latência ou simplicidade são importantes.

TCP x UDP

TCP prioriza confiabilidade; UDP prioriza simplicidade e menor sobrecarga. A escolha depende da aplicação.

7. DNS e DHCP

DNS

Domain Name System traduz nomes de domínio em informações de resolução, normalmente um endereço IP. Assim, usuários podem acessar serviços por nomes como exemplo.com em vez de memorizar endereços numéricos.

Analogia do DNS

É parecido com uma agenda de contatos: você procura um nome e obtém o número correspondente.

DHCP

Dynamic Host Configuration Protocol fornece configurações de rede automaticamente, como endereço IP, gateway e servidores DNS.

8. Web e Criptografia

HTTP

Hypertext Transfer Protocol é usado para comunicação entre clientes, como navegadores, e servidores web.

HTTPS

É HTTP protegido por TLS. O TLS ajuda a fornecer confidencialidade, integridade e autenticação do servidor durante a comunicação.

Criptografia

Transforma dados usando um algoritmo e uma chave para que pessoas não autorizadas não consigam interpretá-los. Pode proteger dados em trânsito e em armazenamento.

Hash

Uma função hash transforma uma entrada em uma representação de tamanho definido. Hash não deve ser tratado como criptografia reversível. É muito usado para integridade, identificação de arquivos e armazenamento seguro de senhas quando combinado com técnicas apropriadas.

9. Identidade e Controle de Acesso

Autenticação

Responde: 'Quem é você?'. Pode envolver senha, biometria, token ou certificado.

Autorização

Responde: 'O que você pode fazer?'. Uma pessoa pode estar autenticada e ainda não ter permissão para acessar um recurso.

Autenticação x Autorização

Autenticação verifica identidade; autorização verifica permissões.

Menor privilégio

Usuários, aplicações e processos devem possuir apenas as permissões necessárias. Isso reduz o impacto de uma conta ou aplicação comprometida.

10. Segurança da Informação

CIA Triad

A tríade CIA representa Confidentiality, Integrity e Availability: confidencialidade, integridade e disponibilidade.

Confidencialidade

Evita acesso não autorizado às informações.

Integridade

Evita alterações indevidas e ajuda a garantir que os dados permaneçam corretos.

Disponibilidade

Busca manter sistemas e dados acessíveis quando necessários.

Defesa em profundidade

Usa várias camadas de proteção. Se uma camada falhar, outras podem reduzir o impacto. Exemplos: MFA, firewall, EDR, controle de acesso, monitoramento e backup.

Firewall

Controla tráfego de rede com base em regras. Pode bloquear ou permitir conexões e existir em equipamentos, servidores, sistemas operacionais e serviços em nuvem.

11. Malware e Engenharia Social

Malware

É um termo amplo para software malicioso. Inclui vírus, worms, trojans, ransomware, spyware e outros tipos.

Vírus

Malware associado historicamente à necessidade de um hospedeiro, arquivo ou programa para se replicar ou executar.

Worm

Malware capaz de se propagar automaticamente entre sistemas, sem depender da mesma interação manual exigida por muitos vírus.

Trojan

Programa que aparenta ser legítimo ou útil, mas possui comportamento malicioso ou não autorizado.

Ransomware

Malware que normalmente criptografa ou bloqueia dados e exige pagamento. Pode causar indisponibilidade, perdas financeiras e interrupção operacional.

Spyware

Software usado para monitorar ou coletar informações de forma indevida.

Engenharia social

Explora manipulação psicológica para induzir pessoas a realizar ações inseguras. O atacante pode mirar o fator humano em vez de explorar diretamente uma máquina.

Phishing

Forma de engenharia social que usa mensagens ou páginas enganosas para induzir a vítima a revelar informações ou realizar ações.

12. SOC, EDR, SIEM e Logs

SOC

Security Operations Center é uma estrutura dedicada ao monitoramento e operação de segurança. Analistas avaliam eventos, investigam alertas e ajudam na resposta.

EDR

Endpoint Detection and Response monitora endpoints e coleta dados sobre processos, arquivos, conexões, usuários e comportamentos para detectar e investigar atividades suspeitas.

SIEM

Security Information and Event Management centraliza e correlaciona logs e eventos de várias fontes para facilitar monitoramento, investigação e auditoria.

Log

É um registro de eventos. Pode conter horário, usuário, IP, ação, sistema e resultado. Logs são fundamentais para reconstruir acontecimentos.

Relação SOC x SIEM x EDR

SOC é a operação/equipe; SIEM é uma plataforma que centraliza e correlaciona eventos; EDR é uma solução focada na visibilidade e resposta em endpoints.

13. Incidentes e Indicadores

Incidente de segurança

É um evento que compromete ou pode comprometer a segurança. Exemplos: conta comprometida, malware detectado, acesso não autorizado ou execução suspeita.

Falso positivo

Ocorre quando uma solução gera um alerta para uma atividade que parece suspeita, mas é legítima. Por isso, alerta não significa automaticamente incidente confirmado.

IOC

Indicator of Compromise é uma evidência ou indicador que pode sugerir comprometimento. Exemplos: hash malicioso, IP suspeito, domínio, arquivo, processo ou comportamento anormal.

Como investigar um alerta

Pergunte: o que aconteceu? quando? onde? quem estava envolvido? como aconteceu? qual o impacto? o evento é legítimo ou malicioso? quais ações devem ser tomadas?

14. Blue Team e Red Team

Blue Team

Foca na defesa: monitoramento, detecção, prevenção, investigação, hardening, resposta a incidentes e melhoria dos controles.

Red Team

Executa testes ofensivos autorizados para simular ataques e encontrar caminhos de exploração.

Relação

Red Team pergunta 'como um atacante poderia entrar?'; Blue Team pergunta 'como detectaríamos, impediríamos ou limitaríamos isso?'. Conhecer ataques ajuda o defensor a criar controles melhores.

15. Vulnerabilidades, Riscos e Hardening

Vulnerabilidade

É uma fraqueza em software, configuração, processo, sistema ou comportamento humano que pode ser explorada.

Ameaça

É um agente, evento ou situação capaz de causar dano.

Risco

É a possibilidade de uma ameaça explorar uma vulnerabilidade e gerar impacto. Probabilidade e impacto ajudam a definir prioridade.

Vulnerabilidade x Exploit

Vulnerabilidade é a fraqueza; exploit é a técnica, código ou mecanismo usado para explorar essa fraqueza.

Hardening

É o fortalecimento de um sistema para reduzir a superfície de ataque. Inclui atualizar sistemas, remover serviços desnecessários, restringir portas, aplicar menor privilégio e reforçar autenticação.

Superfície de ataque

É o conjunto de pontos potencialmente expostos a exploração, como portas, serviços, aplicações, APIs, contas e dispositivos.

16. Engenharia Reversa e Laboratórios

Engenharia reversa

É a análise de um software, sistema ou artefato para compreender como ele funciona. Em segurança pode apoiar investigação de malware, vulnerabilidades, protocolos e incidentes.

Engenharia reversa de malware

Pode buscar entender processos, arquivos alterados, conexões, mecanismos de persistência e indicadores deixados pelo malware.

Laboratório seguro

Práticas ofensivas e análises devem ocorrer em ambientes próprios ou explicitamente autorizados. O objetivo é aprender sem colocar sistemas reais ou terceiros em risco.

17. Revisão Comparativa

IP x Porta

IP identifica o destino lógico; porta identifica o serviço ou aplicação associado à comunicação.

DNS x IP

DNS resolve nomes; IP é usado para endereçar e encaminhar comunicação.

Switch x Roteador

Switch conecta dispositivos dentro da LAN; roteador conecta redes diferentes.

TCP x UDP

TCP prioriza confiabilidade; UDP tem menor sobrecarga e não fornece as mesmas garantias.

Autenticação x Autorização

Autenticação: quem você é. Autorização: o que você pode fazer.

Vulnerabilidade x Exploit

Vulnerabilidade: fraqueza. Exploit: mecanismo de exploração.

Ameaça x Risco

Ameaça pode causar dano; risco representa a possibilidade de exploração e impacto.

Blue Team x Red Team

Blue Team defende; Red Team simula ataques de forma autorizada.

Log x Alerta

Log registra eventos; alerta indica que um evento ou conjunto de eventos merece atenção.

SOC x SIEM x EDR

SOC é a operação; SIEM centraliza/correlaciona eventos; EDR dá visibilidade e resposta em endpoints.

18. Glossário

DNS

Domain Name System — sistema de resolução de nomes.

DHCP

Dynamic Host Configuration Protocol — configuração automática de rede.

IP

Internet Protocol — endereçamento e encaminhamento.

MAC

Media Access Control — identificador de interface de rede.

TCP

Transmission Control Protocol — comunicação orientada à conexão.

UDP

User Datagram Protocol — protocolo simples e sem as mesmas garantias do TCP.

HTTP

Hypertext Transfer Protocol — comunicação web.

HTTPS

HTTP protegido por TLS.

TLS

Transport Layer Security — protocolo de segurança usado para proteger comunicações.

EDR

Endpoint Detection and Response.

SIEM

Security Information and Event Management.

SOC

Security Operations Center.

IOC

Indicator of Compromise.

MFA

Multi-Factor Authentication — autenticação com múltiplos fatores.

RDP

Remote Desktop Protocol.

SSH

Secure Shell — acesso remoto seguro.

19. Questões de Fixação

1. Qual é a principal diferença entre autenticação e autorização?

• A) Autenticação verifica identidade; autorização verifica permissões.

• B) Autenticação define portas; autorização define IP.

• C) São exatamente a mesma coisa.

• D) Não sei.

2. Para que serve o DNS?

• A) Criptografar todos os arquivos do computador.

• B) Resolver nomes de domínio e fornecer informações como endereços IP.

• C) Substituir o firewall.

• D) Não sei.

3. Qual equipamento normalmente conecta redes diferentes?

• A) Switch

• B) Roteador

• C) Teclado

• D) Não sei.

4. Qual característica diferencia o TCP do UDP?

• A) TCP possui mecanismos de confiabilidade e ordenação; UDP é mais simples e não oferece as mesmas garantias.

• B) UDP sempre é mais seguro.

• C) TCP só funciona em redes locais.

• D) Não sei.

5. O que é um IOC?

• A) Um tipo de roteador.

• B) Um indicador que pode sugerir comprometimento.

• C) Um protocolo de e-mail.

• D) Não sei.

6. O que caracteriza um falso positivo?

• A) Um ataque confirmado.

• B) Um alerta sobre uma atividade que parece suspeita, mas é legítima.

• C) Um usuário sem senha.

• D) Não sei.

7. Qual é o objetivo do hardening?

• A) Aumentar a superfície de ataque.

• B) Fortalecer o sistema e reduzir exposição.

• C) Desligar todos os servidores.

• D) Não sei.

8. Qual é a função principal de um EDR?

• A) Monitorar endpoints e apoiar detecção e resposta.

• B) Resolver nomes DNS.

• C) Substituir o sistema operacional.

• D) Não sei.

9. O que representa a tríade CIA?

• A) Confidencialidade, Integridade e Disponibilidade.

• B) Código, Internet e Autenticação.

• C) Controle, Inteligência e Ataque.

• D) Não sei.

10. Qual é a relação entre vulnerabilidade e exploit?

• A) Vulnerabilidade é a fraqueza; exploit é o mecanismo usado para explorá-la.

• B) São sinônimos.

• C) Exploit é sempre um firewall.

• D) Não sei.

Gabarito: 1-A, 2-B, 3-B, 4-A, 5-B, 6-B, 7-B, 8-A, 9-A, 10-A.

Encerramento

Este material deve ser usado como base de revisão. Quando um conceito ainda não estiver claro, a prioridade é voltar à explicação e testar a compreensão, em vez de decorar a resposta. O objetivo da formação em Cybersecurity é conseguir conectar fundamentos de sistemas, redes e segurança com situações práticas de monitoramento, investigação e defesa.